Registro de Decisiones de Arquitectura (ADR)

Plataforma de Farmacología Gamificada — Lote 5 (ADR-0016 y ADR-0017)

Versión 1 — OFICIAL

Fecha del documento: 27 de octubre de 2026

Decisiones tomadas al completar el módulo de Autenticación: recuperación de contraseña y asignación de roles. Complementan los lotes 1 a 4 sin reemplazar ninguna decisión anterior.

ADR-0016: Recuperación de contraseña con enlace de un solo uso

Fecha: 27 de octubre de 2026

Estado: Aceptada

Contexto

Los requisitos (sección 5.1) incluyen la recuperación de contraseña. El mecanismo debe ser seguro sin infraestructura de nivel bancario (ADR-0008), compatible con un backend sin estado (ADR-0003) y no debe permitir averiguar qué correos están registrados. El proveedor de correo electrónico todavía no está elegido.

Opciones consideradas

- Enviar una contraseña temporal por correo.
- Enviar un enlace con un JWT firmado de corta duración (sin guardar nada en la base de datos).
- Enviar un enlace con un token aleatorio de un solo uso, guardando en la base de datos solo su hash.

Decisión

Se adopta el enlace con token aleatorio de un solo uso. El token tiene 32 bytes aleatorios y viaja solo en el enlace del correo; en la tabla autenticacion_tokens_recuperacion se guarda únicamente su hash SHA-256. El enlace vence a los 30 minutos y pedir uno nuevo invalida los anteriores sin usar.

Al restablecer, en una sola transacción se marca el token como usado (solo si sigue vigente y sin usar), se cambia la contraseña y se eliminan los demás tokens pendientes del usuario. Así, dos peticiones simultáneas con el mismo token no pueden usarlo dos veces.

La solicitud responde siempre el mismo mensaje, exista o no la cuenta, y el envío del correo no se espera, para no delatar por tiempo de respuesta. El envío se hace a través del puerto EnviadorCorreos; mientras se elige el proveedor real, el adaptador EnviadorCorreosConsola muestra el correo en la consola del servidor.

Trade-offs

Aspecto	Análisis
A favor	Quien lea la base de datos no puede usar los tokens (solo ve hashes); el token se puede invalidar en cualquier momento, a diferencia de un JWT; un solo uso y 30 minutos de vigencia limitan el daño si el correo se filtra; no revela qué correos están registrados; el proveedor de correo se puede cambiar sin tocar los casos de uso.
En contra / riesgos	Añade una tabla y escrituras en la base de datos; los JWT de sesión emitidos antes del cambio de contraseña siguen siendo válidos hasta que expiran (máximo el tiempo configurado, hoy 60 minutos); todavía no hay límite de solicitudes por correo o IP, por lo que alguien podría provocar muchos correos a una misma cuenta.

Alternativa descartada

La contraseña temporal por correo deja una credencial utilizable en la bandeja de entrada y obliga a un segundo cambio. El JWT de recuperación no se puede invalidar después de usarlo ni cuando se pide otro enlace, salvo que se guarde estado, con lo que pierde su ventaja.

ADR-0017: Asignación de roles y creación del primer Administrador

Fecha: 27 de octubre de 2026

Estado: Aceptada

Contexto

La plataforma tiene tres roles (Estudiante, Administrador y Creador de Contenido). El registro público solo crea Estudiantes, así que se necesita una forma controlada de asignar los otros roles y de crear el primer Administrador cuando todavía no existe ninguno. El rol viaja dentro del JWT sin estado (ADR-0008).

Opciones consideradas

- Permitir elegir el rol en el registro público.
- Crear el primer Administrador con datos fijos en una migración o semilla de la base de datos.
- Asignar roles por la API solo desde un Administrador, y crear el primer Administrador con un script de consola sobre una cuenta ya registrada.

Decisión

Se adopta la tercera opción. La ruta PATCH /api/autenticacion/usuarios/:usuarioId/rol exige sesión y rol de Administrador (middleware requerirRol), y el caso de uso vuelve a comprobarlo por su cuenta. Un Administrador no puede cambiar su propio rol, para que la plataforma no se quede sin administradores por accidente.

El primer Administrador se crea con npm run asignar-rol -- <correo> administrador, que solo puede ejecutar quien tiene acceso al servidor y a su archivo .env. La cuenta debe existir antes (registro normal).

Como el rol va dentro del JWT, el cambio se aplica desde el siguiente inicio de sesión del usuario; el token vigente conserva el rol anterior hasta expirar.

Trade-offs

Aspecto	Análisis
A favor	Nadie puede darse a sí mismo un rol con privilegios desde la API; no hay contraseñas de administrador fijas en el código ni en el repositorio; la doble comprobación (ruta y caso de uso) protege aunque otro módulo llame a la fachada directamente; mantiene el backend sin estado.
En contra / riesgos	Quitar un rol no es inmediato: la persona conserva sus permisos hasta que su token expire (máximo 60 minutos con la configuración actual); crear el primer Administrador requiere acceso a la consola del servidor.

Alternativa descartada

Elegir el rol en el registro público permitiría que cualquiera se hiciera Administrador. Un Administrador fijo en una semilla obliga a guardar o comunicar una contraseña conocida, que suele quedarse sin cambiar. Si en el futuro se necesita revocar roles al instante, se puede añadir una versión de credenciales al usuario y comprobarla en cada petición.